



ZAP
by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://archive.mozilla.org> <http://localhost:3000>

Generated on czw., 30 kwi 2026 12:45:37

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Poziom ryzyka	Number of Alerts
Wysoki	0
redni	3
Niski	3
Informacyjny	2

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://localhost:3000	Percentage of responses with status code 1xx	3 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 2xx	93 %
Info	Informational	http://localhost:3000	Percentage of responses with status code 3xx	3 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/javascript	33 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type application/json	29 %

Info	Informational	http://localhost:3000	Percentage of endpoints with content type font /woff2	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image /png	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type image /x-icon	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text /css	4 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text /html	8 %
Info	Informational	http://localhost:3000	Percentage of endpoints with content type text /plain	8 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method GET	95 %
Info	Informational	http://localhost:3000	Percentage of endpoints with method POST	4 %
Info	Informational	http://localhost:3000	Count of total endpoints	24
Info	Informational	http://localhost:3000	Percentage of slow responses	34 %
			Percentage of	

Info	Informational	https://archive.mozilla.org	responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with content type application/x-xpinstall	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with method GET	100 %
Info	Informational	https://archive.mozilla.org	Count of total endpoints	1
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %

Zagrozenia

Nazwa	Poziom ryzyka	Number of Instances
Content Security Policy (CSP) Header Not Set	redni	2
Cross-Domain Misconfiguration	redni	Systemic
Session ID in URL Rewrite	redni	3
Private IP Disclosure	Niski	1
Timestamp Disclosure - Unix	Niski	Systemic
X-Content-Type-Options Header Missing	Niski	4
Information Disclosure - Suspicious Comments	Informacyjny	3
Retrieved from Cache	Informacyjny	1

Alert Detail

redni	Content Security Policy (CSP) Header Not Set
Opis	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Metody	GET
Atak	

Evidence	
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dI5&sid=iSggM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	
Other Info	
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

redni	Cross-Domain Misconfiguration
Opis	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	http://localhost:3000/chunk-24EZLZ4I.js
Node Name	http://localhost:3000/chunk-24EZLZ4I.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/chunk-TWZW5B45.js
Node Name	http://localhost:3000/chunk-TWZW5B45.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from

Info	authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/chunk-YPG2SXXJ.js
Node Name	http://localhost:3000/chunk-YPG2SXXJ.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/polyfills.js
Node Name	http://localhost:3000/polyfills.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:3000/scripts.js
Node Name	http://localhost:3000/scripts.js
Metody	GET
Atak	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	Systemic
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Opis	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history or server logs.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dIA&sid=iSqqM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Metody	GET
Atak	
Evidence	iSqqM7d12ruWsk0MAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=websocket&sid=iSqqM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,transport)
Metody	GET
Atak	
Evidence	iSqqM7d12ruWsk0MAAAA
Other Info	
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dI5&sid=iSqqM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	iSqqM7d12ruWsk0MAAAA
Other Info	
Instances	3
Solution	For secure content, put session ID in a cookie. To be even more secure consider using a combination of cookie and URL rewrite.
Reference	https://seclists.org/webappsec/2002/q4/111
CWE Id	598
WASC Id	13
Plugin Id	3

Niski	Private IP Disclosure
Opis	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://localhost:3000/rest/admin/application-configuration
Node Name	http://localhost:3000/rest/admin/application-configuration
Metody	GET
Atak	
Evidence	192.168.99.100:3000

Other Info	192.168.99.100:3000 192.168.99.100:4200
Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
CWE Id	497
WASC Id	13
Plugin Id	2

Niski	Timestamp Disclosure - Unix
Opis	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Metody	GET
Atak	
Evidence	1650485437
Other Info	1650485437, which evaluates to: 2022-04-20 22:10:37.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Metody	GET
Atak	
Evidence	1981395349
Other Info	1981395349, which evaluates to: 2032-10-14 21:35:49.
URL	http://localhost:3000/
Node Name	http://localhost:3000/
Metody	GET
Atak	
Evidence	2038834951
Other Info	2038834951, which evaluates to: 2034-08-10 17:02:31.
URL	http://localhost:3000/styles.css
Node Name	http://localhost:3000/styles.css
Metody	GET
Atak	
Evidence	1701244813
Other Info	1701244813, which evaluates to: 2023-11-29 09:00:13.
URL	http://localhost:3000/styles.css
Node	

Name	http://localhost:3000/styles.css
Metody	GET
Atak	
Evidence	2033195021
Other Info	2033195021, which evaluates to: 2034-06-06 10:23:41.
Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Niski	X-Content-Type-Options Header Missing
Opis	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dIA&sid=iSqgM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)
Metody	GET
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dEJ
Node Name	http://localhost:3000/socket.io/ (EIO,t,transport)
Metody	GET
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-151.4.0-build1/newtab.xpi
Node Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-151.4.0-build1/newtab.xpi
Metody	GET
Atak	
Evidence	
	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still

Other Info	affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:3000/socket.io/?EIO=4&transport=polling&t=PtT-dl5&sid=iSqqM7d12ruWsk0MAAAA
Node Name	http://localhost:3000/socket.io/ (EIO,sid,t,transport)(40)
Metody	POST
Atak	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informacyjny	Information Disclosure - Suspicious Comments
Opis	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:3000/chunk-BYFFE6ZA.js
Node Name	http://localhost:3000/chunk-BYFFE6ZA.js
Metody	GET
Atak	
Evidence	db
Other Info	The following pattern was used: \bDB\b and was detected in likely comment: "//angular.dev/best-practices/security#preventing-cross-site-scripting-xss",v=class extends Error{code; constructor(t,n){super(Ye(" see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/chunk-MDFPGS4J.js
Node Name	http://localhost:3000/chunk-MDFPGS4J.js
Metody	GET
Atak	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "//"))` :t} else{let t=dh(i,(e,r)=>r===w?[Zi(i.children[w],!1)]:['\${r}:\${Zi(e,!1)}'}]);return Object.keys(i.children).length===1&&i", see evidence field for the suspicious comment/snippet.
URL	http://localhost:3000/main.js
Node Name	http://localhost:3000/main.js

Metody	GET
Atak	
Evidence	query
Other Info	The following pattern was used: \bQUERY\b and was detected in likely comment: "/" + e.host),typeof t=="string"&&(t.charAt(0)=="/"&&(t.charAt(1)=="/"?t=e.protocol+t:e.host+t),/^(https? wss?):V/.test(t)]", see evidence field for the suspicious comment/snippet.
Instances	3
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informacyjny	Retrieved from Cache
Opis	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://archive.mozilla.org/pub/system-addons/newtab/newtab-151.4.0-build1/newtab.xpi
Node Name	https://archive.mozilla.org/pub/system-addons/newtab/newtab-151.4.0-build1/newtab.xpi
Metody	GET
Atak	
Evidence	HIT
Other Info	
Instances	1
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050